Lab 5: Static Code Analysis

Society Dues (L5_17_society_dues)

Name: Shalik S
SRN: PES2UG24CS454
Section: H

1. Before Correcting the Code

1.1 Bandit Report (Before)

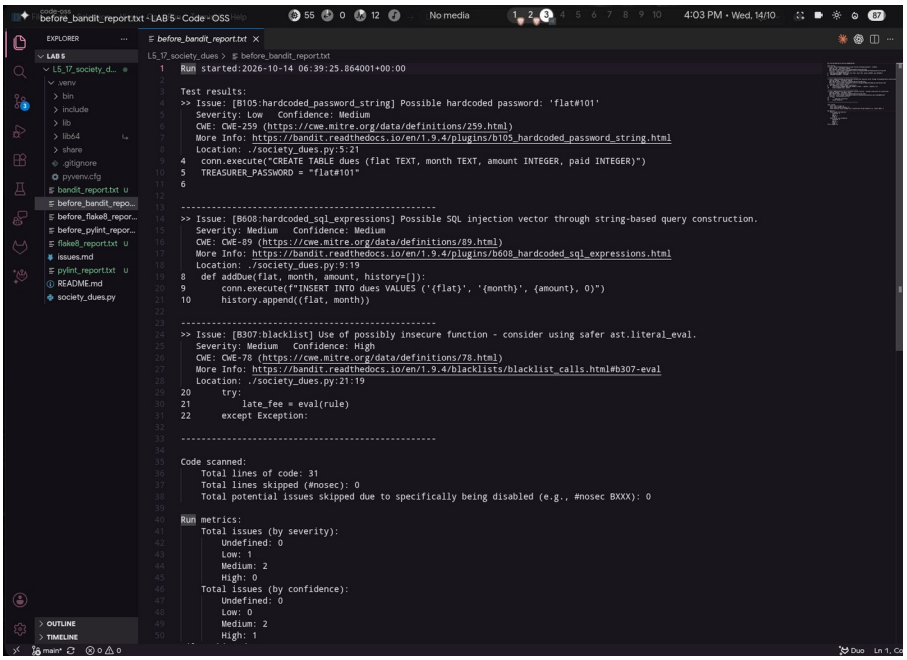


Figure 1: Bandit report before fixes – 3 issues (1 Low, 2 Medium)

1.2 Flake8 Report (Before)

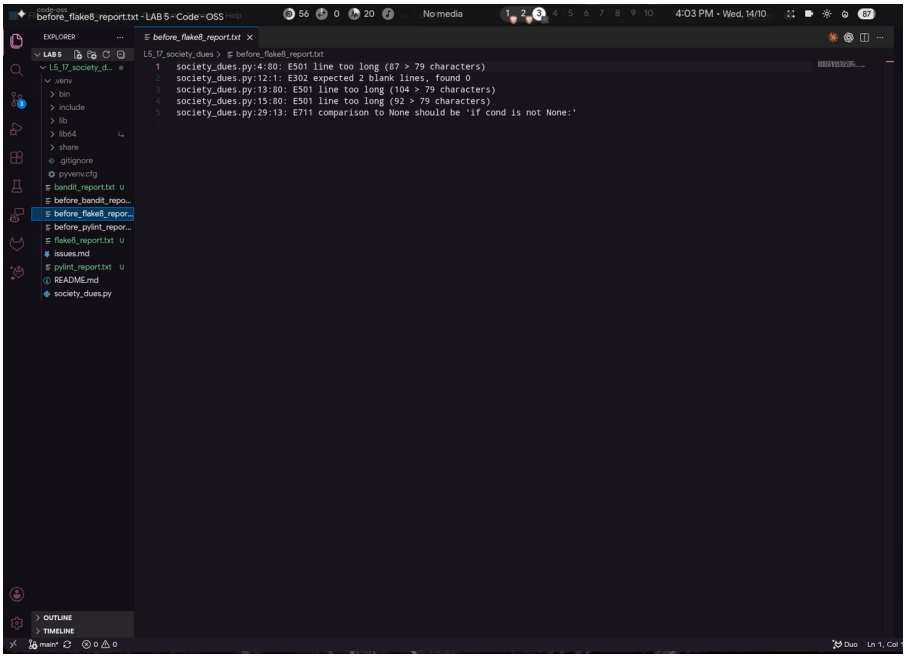


Figure 2: Flake8 report before fixes – E501, E302, E711

1.3 Pylint Report (Before)

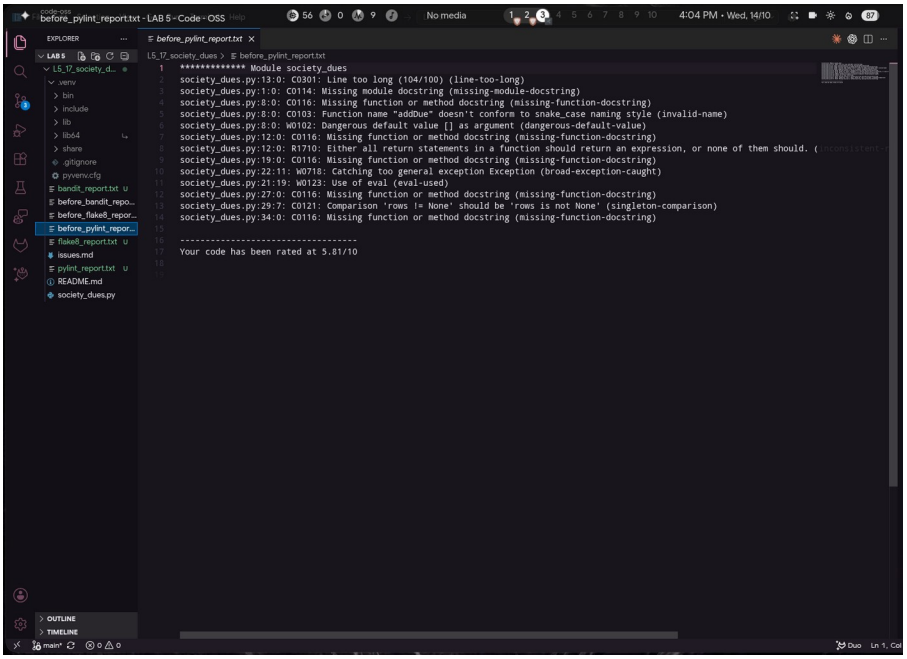


Figure 3: Pylint report before fixes – rated 5.81/10

2. Issues Identified

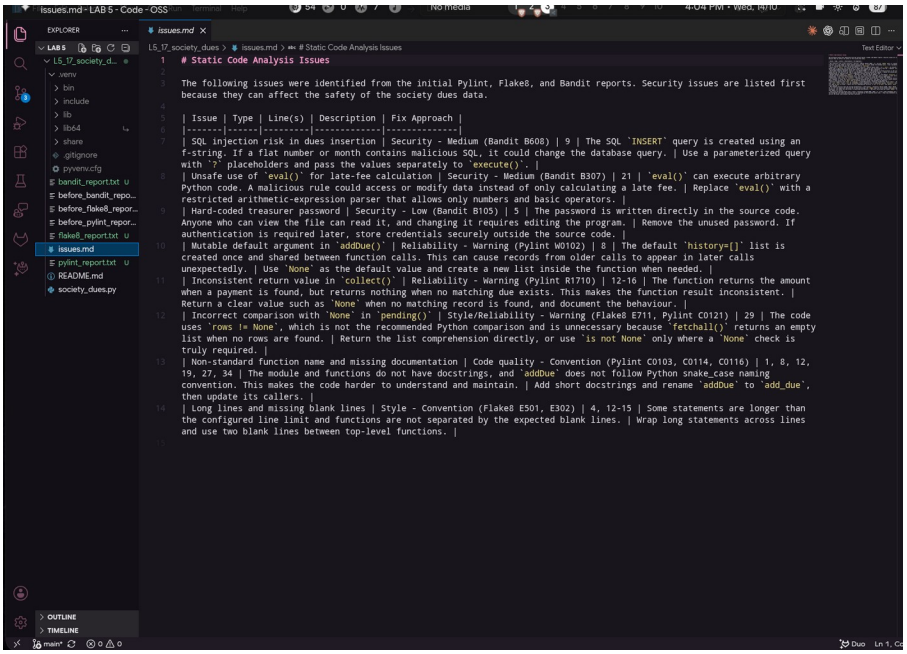


Figure 4: issues.md – summary of issues and fix approach

3. After Correcting the Code

3.1 Bandit Report (After)

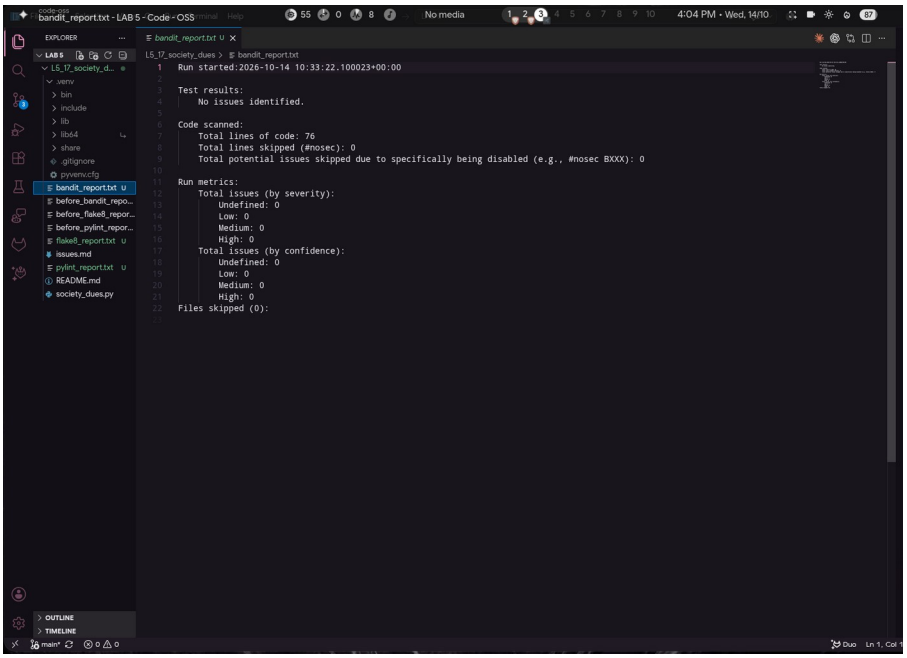


Figure 5: Bandit report after fixes – no issues identified

3.2 Flake8 Report (After)

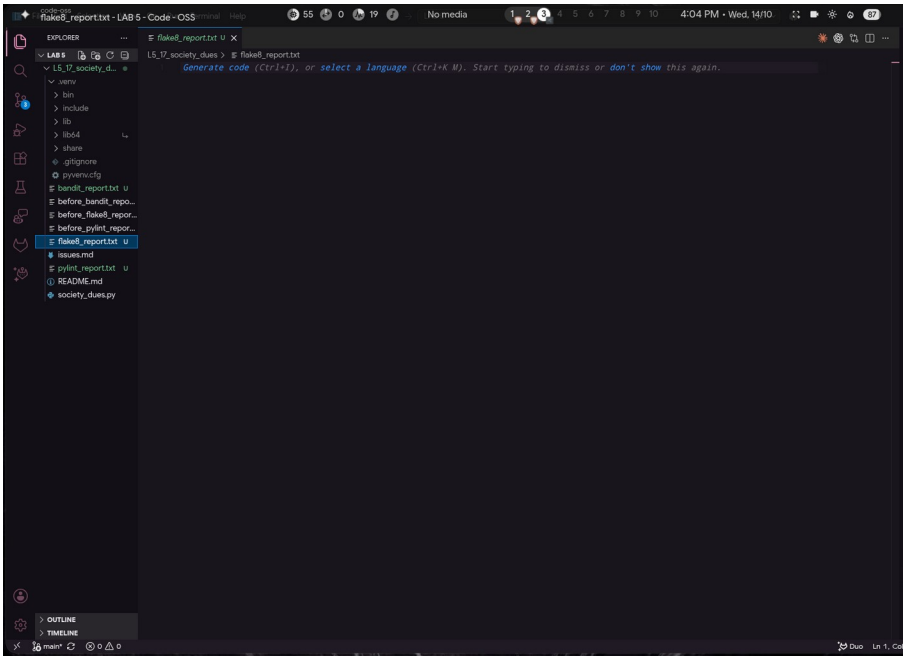


Figure 6: Flake8 report after fixes – empty report (no warnings)

3.3 Pylint Report (After)

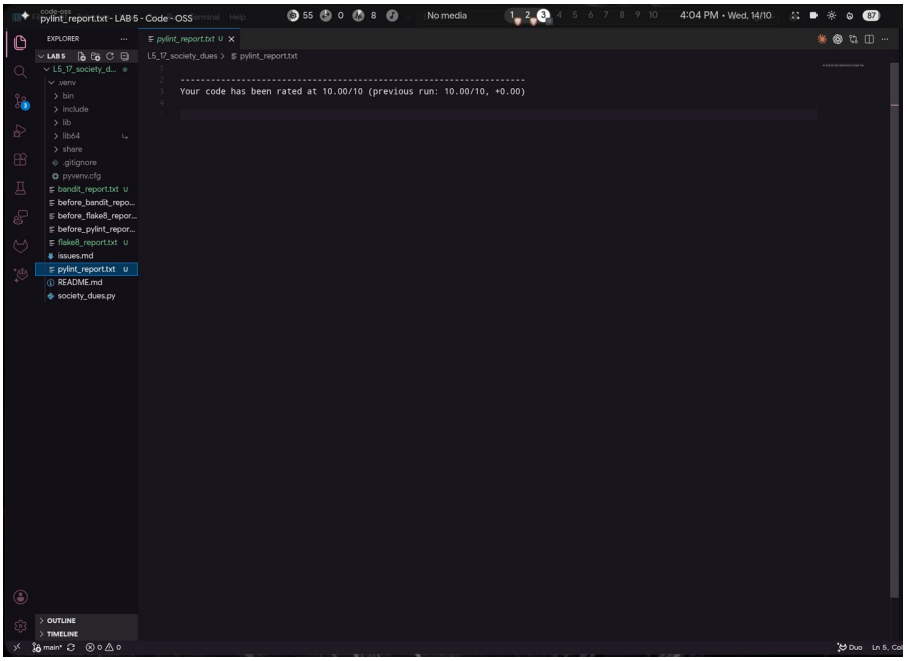


Figure 7: Pylint report after fixes – rated 10.00/10

4. Issues Found and Fixes Applied

The following issues were reported by Bandit, Flake8 and Pylint, and the fixes below were applied to society_dues.py. After the fixes, Bandit reports no issues, Flake8 reports no warnings, and Pylint rates the code 10.00/10 (up from 5.81/10).

Issue	Problem	Fix Applied
SQL injection in dues insertion (Bandit B608, Medium)	INSERT query built with an f-string, so a malicious flat number or month could alter the query.	Replaced with a parameterized query using ? placeholders; values passed separately to execute().
Unsafe eval() for late fee (Bandit B307, Medium)	eval() can run arbitrary Python code from the rule string.	Replaced eval() with a restricted arithmetic-expression parser allowing only numbers and basic operators.
Hard-coded treasurer password (Bandit B105, Low)	Password stored in source code and unused.	Removed the password from the code.
Mutable default argument in addDue() (Pylint W0102)	history=[] is created once and shared across calls.	Default changed to None; a new list is created inside the function.
Inconsistent return in collect() (Pylint R1710)	Returns the amount if found, nothing otherwise.	Now returns None explicitly when no matching record exists; behaviour documented.
Comparison with None in pending() (Flake8 E711, Pylint C0121)	rows != None is not the recommended comparison and is unnecessary.	Returns the list comprehension directly (fetchall() gives an empty list when no rows).
Naming and missing docstrings (Pylint C0103, C0114, C0116)	Module and functions lacked docstrings; addDue not in snake_case.	Added docstrings and renamed addDue to add_due, updating its callers.
Long lines and blank lines (Flake8 E501, E302)	Lines over 79 characters; missing blank lines between functions.	Wrapped long statements and used two blank lines between top-level functions.